CUI//SP-CONTRACT

Correspondence Tracking System Operations and Maintenance

Performance Work Statement

Office of the Secretary

U.S. Department of Education

07.28.2026

General Information

1 Description of Services/Introduction:

1.1 Description of Services/Introduction: The contractor shall provide all personnel, equipment, tools, materials, supervision, and other items and non-personal services necessary to maintain a fully functioning/operational OS Correspondence Tracking System (CTS) in the production environment and perform operations and maintenance of the system as defined in this Performance Work Statement. The contractor shall perform to the standards in this order.

1.2 Background: The Office of the Secretary (OS), Executive Secretariat (Exec Sec) is seeking a contractor to perform daily Operations and Maintenance (O&M), fix bugs, and complete other minor enhancements.

CTS provides the ability to track in real-time the status of correspondence packages being processed in the Department. CTS was developed on the Appian Cloud Platform with a MySQL database as the repository.

2 Objectives

Perform daily Operations and Maintenance (O&M), fix bugs, and complete other minor enhancements.

This objective is broken down into the following sub-objectives:

- Implement minor enhancements
- Provide Operations and Maintenance
- Transition Out Support Services, if necessary

3 Scope

The scope of this requirement is to continue to maintain authorization to operate, train stakeholders, and provide operations and maintenance support for the Correspondence Tracking System (CTS). The scope of the services in this PWS are as follows:

Assuming responsibility for all pre-production activities and support duties for functioning of CTS, and Transition Out phase, which requires providing support services to ensure an orderly transition of functions from this Task Order to the successor Contractor.

The support includes IT project management and technical expertise to help ensure the Department effectively maintains the solution to meet Exec Sec business needs, as well as obtain the most value it provides. Specifically, the goal is to ensure that the application continues to meet the Department's correspondence tracking needs and that technical business requirements remain functional.

4 Task Areas:

4.1 Task 1 –Maintain Authorization to Operate (ATO) (Base + option years)

4.1.1 The Contractor shall:

Support Exec Sec with the steps necessary to maintain an ATO in the Department's enterprise (Base and all option years). The contractor shall support the Project Manager (PM) and Information Systems Security Officer (ISSO) with development of materials for review and approval by the Department's Information Assurance Services (IAS) Division and other internal and external organizations needed to maintain security to operate the system on the Department's network.

Specifically, the contractor must continue support the ATO security work to include:

- Review all security assessment requirements and documentation
- Interface with security leads on all required meetings and interviews
- Identify and communicate to the Government any security-related issues or concerns that need to be addressed to maintain an ATO for the Appian cloud-based system.
- Provide responses to all security team questions and requests
- Interface with technical resources OCIO (PIVOT) and application vendor (Appian) to attain the latest security information in response to inquiries as well as updating the Cyber Security Assessment Management (CSAM) system security controls and documentation
- Update CSAM documentation and security controls at intervals prescribed by the Department (quarterly, annually etc.)
- Coordinate required vulnerability scans, review results, and eliminate or coordinate with internal and external Department personnel to eliminate vulnerabilities
- Work to remediate findings, gaps and vulnerabilities as needed

4.1.2 Deliverables:

- Maintain Authorization to Operate
- All Cyber Security related documents

4.2 Task 2 – Maintain Jira Backlog and Deploy the System to the Production Environment for Break-Fix Releases

4.2.1 The Contractor shall:

- Work collaboratively with the customer, using agile development best practices, to deploy changes to the production environment fully functioning/operational break-fix features/components of the Jira backlog on an incremental release schedule.
- Work collaboratively with the customer in prioritizing the release of break-fix features/components such that the most beneficial features/components are deployed to the production environment early in the life cycle.
- Ensure changes to the system are released in a controlled and managed process through all environments (Development, Test, Production).
- Establish a testing program including functional testing, integration testing and regression testing. Section 508 testing is to be completed by the DoED.
- Present the status of testing and test results using quantifiable metrics (e.g., number of test

cases pass vs. fail, number of requirements pass vs. fail, number of high/medium/low defects).
- Provide ED Principal Offices with formal briefings as requested.

4.2.2 Deliverables:

Briefings as needed.

4.3 Task 3 – Provide Operations and Maintenance (Base and all option periods)

4.3.1 The Contractor shall:

- Maintain a project management system which establishes and maintains an integrated baseline plan that provides a view of the project schedule, resource utilization, and performance throughout the life cycle.
- Maintain a risk management system, which identifies risks and mitigation plans, and provides for special emphasis on cost controls, time management, continuous improvement, and ongoing task monitoring.
- Maintain the help desk system, which will complement the Government's help desk system, to ensure the tracking and resolution of system issues, bugs, enhancement requests, user access requests, etc.
- Provide help desk summary and detail reports and system uptime reports using quantifiable metrics (e.g., number of issues open vs. closed, average number of days open, system uptime percentage, number of issues by root cause).
- Work collaboratively with users, system administrators, developers, and other stakeholders as needed to resolve system issues, such as system outages, bugs, etc.
- Schedule and participate in regular check-ins (i.e., weekly or bi-weekly) with program staff to discuss any outstanding issues at a mutually agreed-upon time between the hours of 9am-5:30pm, Monday – Friday, Eastern Time.
- Work collaboratively with the OCIO to address any security vulnerabilities through a variety of methods, such as applying security patches, modifying software code, re-configuring system settings, etc.
- Follow all established change management procedures to ensure changes introduced to the production environment are thoroughly tested and can be rolled back if needed.
- Configure and maintain appropriate system permissions and other system settings.

4.3.2 The contractor shall also provide continuing investment management support. Specific IT investment management process support includes:
- Operational analysis. Conduct the annual operational analysis to assess system performance and identify opportunities for improved service delivery, cost savings, etc.
- IT investment support. Support IT investment reporting including but not limited to updates of the business case, Technology Business Management (TBM) process, IT funding needs, program assessments, and Federal Information Technology Acquisition Reform Act (FITARA) requirements.

4.3.3 Deliverables:

- Project schedule
- Risk registry
- Help Desk ticket Summary and Detail Report

4.4 Task 4 – Transition Out Services (Optional Task – Base & All Option Years)

4.4.1 The Contractor shall:

Transition out services between contract vendors, if necessary.

The contractor will collaborate with the PM, COR and ISSO, to develop and maintain a transition plan to transition services between contract vendors. The contractor shall provide solutions and materials to the Department for transitioning all system support services identified in this requirement. Tasks shall include, but not be limited to the following:

- Providing information on JIRA backlog, if any.
- Providing information on all system service account passwords.

4.4.2 Deliverables:

- Project Artifacts.

5 Key Personnel Qualifications

The Contractor shall provide qualified personnel with the certifications, experience, and technical expertise necessary to perform the requirements identified in this Performance Work Statement (PWS). The Contractor shall ensure that Key Personnel possess the qualifications necessary to support application operations, maintenance, development, enhancement, and technical support activities.

The following positions are designated as minimum Key Personnel:

5.1 Project Manager

The Contractor shall provide a Project Manager responsible for managing contract activities, coordinating Contractor resources, supporting communication between the Contractor and Government stakeholders, and ensuring successful execution of PWS requirements.

The Project Manager shall:

- Possess a Project Management Institute (PMI) certification or comparable project management certification, or demonstrate equivalent project management experience;
- Possess Appian certification applicable to the assigned role; and

- Demonstrate a minimum of three (3) years of experience supporting Federal Government information systems of similar size, scope, complexity, and technical environment.

5.2 Appian/Application Developer(s)

The Contractor shall provide Appian/Application Developer(s) responsible for application development, configuration, maintenance, enhancement, troubleshooting, testing, and technical support activities required to support the systems identified in this PWS.

The Appian/Application Developer(s) shall:

- Possess Appian certification applicable to the assigned role;
- Demonstrate a minimum of three (3) years of experience supporting Federal Government information systems of similar size, scope, complexity, and technical environment; and
- Demonstrate a minimum of three (3) years of experience with Agile product development and implementation.

5.3 Key Personnel Changes

The Contractor shall maintain continuity of Key Personnel throughout the period of performance. The Contractor shall notify the Contracting Officer and Contracting Officer's Representative (COR) of any anticipated changes to Key Personnel.

Any proposed replacement of Key Personnel shall possess qualifications, certifications, and experience that are equal to or greater than the qualifications of the individual being replaced. The Contractor shall provide advance notification of proposed substitutions and coordinate an orderly transition to minimize disruption to Government operations. Key personnel changes must be approved by the Contracting Officer.

6 Performance Standards

The contractor shall meet standard Federal guidance and requirements for Federal information systems including but not limited to security requirements, section 508 accessibility requirements, privacy requirements, departmental guidance, and OMB memos M-17-06 and M-10-23. Additional performance standards for the Task Order are as follows:

Task Area	Performance Standard	Acceptable Quality Level (AQL)	Method of Surveillance
Task 2 – Maintain Jira Backlog and Deploy the System to the Production Environment for Break-Fix Release	The system will be high quality and free of defects.	No more than two "low priority" defects (i.e., no impact to production operations) reported per release. Zero defects rated higher than "low priority" per release.	Review Test Results Monthly review of Help Desk Summary and Detail reports
Task 3 – Provide Operations and Maintenance	The Contractor's Help Desk will be responsive to issues.	Respond to users within one hour of reported issue during business hours of 9am-5:30pm Eastern Time.	Monthly review of Help Desk Summary and Detail Report
Task 4 - Transition Services (if necessary)	The Contractor shall transition services, if necessary.	JIRA backlog and system service account passwords are received.	JIRA backlog and system service account passwords are received.

7 Deliverables Schedule

Deliverable	**Schedule**	**Submit To**
Briefings	As needed.	Federal PM
Project schedule	Within 15 days of award.	Federal PM/COR
Risk registry	Within 15 days of award.	Federal PM/COR
Help Desk ticket Summary and Detail Report	Initial due within 7 days of system go live date; weekly thereafter.	Federal PM
Other Project Management Document Requirements	As required by OCIO Enterprise Project Management Office.	Federal PM/COR

8 Period of Performance

The period of performance consists of one 12-month base year and four 12-month option years.

9 Government Furnished Equipment and Information

Standard laptops needed by the vendor to perform any configuration requirements within ED's network will be made available within one week of request.

The equipment will be issued in as-is condition, and the contractor is responsible for inspecting the device upon receipt and notifying the Government of any deficiencies that would impede performance. GFE laptops are intended solely for official duties carried out in support of this effort. Contractor staff must maintain the equipment in good working order and comply with all applicable Government policies regarding security, use, and data protection. The device may not be altered, transferred, or used for purposes outside the scope of this contract. Any incident involving loss, damage, unauthorized access, or misuse must be reported to the COR immediately.
The Government will ensure that all required system access, credentials, and configurations—such as EDCAPS access and any necessary certificates—are provisioned for the contractor personnel assigned to this work. This provisioning will be completed within a reasonable timeframe following receipt of the contractor's onboarding information. At the conclusion of the contract, or upon a change in assigned personnel, the contractor will return all Government-furnished equipment to the Government in accordance with established return procedures.

10 Place of Performance

The primary place of performance is determined by the Contractor (i.e., either remotely or in the Contractor's office location). However, during periods of intense collaboration with Department of Education stakeholders and end-user representatives (e.g., requirements gathering sessions, testing, training) the Contractor's presence may be requested at the Department of Education's headquarters location in Washington, DC. Contractor will be given 14-calendar-days-notice by the Contracting Officer's Representative if their presence is requested at ED headquarters.

11 Standard Contractor IT Requirements

If a cloud solution will be used, an ED-issued, FedRAMP-Compliant Authorization to Operate (ATO) is a Federal and a Departmental requirement, and one must be obtained.

11.1 Information Assurance Requirements

The Contractor and any sub-contractors must comply with all applicable regulations and provisions in the document "Security and Privacy Requirements for Information Technology Procurements" available at the following link:
https://www2.ed.gov/fund/contract/about/acs/2020-security-privacy.pdf

11.2 Additional Requirements

As noted above all contractors and subcontractors must comply with the language in the September 2020 "Security and Privacy Requirements for Information Technology Procurements" with exception of, and in addition to:

- E-Government Act of 2002 has been superseded by FISMA 2014 (Federal Information Security Modernization Act) of 2014. All contractors and subcontractors shall comply with all FISMA 2014 provisions.
- All contractors and subcontractors shall comply with the most current, finalized version of the NIST Special Publication 800 series (as amended).
- If there will be any access to Controlled Unclassified Information (CUI), or to the U.S. Department of Education (ED) resources, systems, or equipment, then in accordance

with The United States Department of Education (ED) Acquisition Alert 2020-01, "Education Acquisition Regulation (EDAR) Class Deviation: Cyber and Personnel Security Requirements for Contractors," dated December 10, 2019, which is (or will be) posted on the external ED.Gov site, at: https://www2.ed.gov/policy/fund/reg/clibrary/acquisition-alert-2020-01.pdf and which is also posted (or will be), on the Department of Education's Acquisition Alert site, at: https://connected.ed.gov/ofo/cam/Pages/Acquisition-Alerts.aspx: All Contractors and subcontractors shall comply with the DEVIATIONs to the two (2) Department Security Requirements clauses, referenced in the following required action: Required Action: Contracting Officers shall include the provision, 3452.239-71 "Notice to offerors of Department security requirements (DEVIATION)" in all new solicitations and contracts, and clause, 3452.239-72 "Department security requirements (DEVIATION)" in all new solicitations and contracts, as applicable. Within 90 days contracting officers shall modify existing contracts, to include 3452.239-72

- All contractors and subcontractors shall comply with requirements that all Department systems, application appliances, or website/web services:
    - Support Elliptic Curve Diffie-Hellman (ECDHE) suites to enable forward secrecy with servers and web browsers. "Forward secrecy", also known as perfect forward secrecy, is a property of secure communication protocols in which compromises of long-term keys does not compromise past session keys. Forward secrecy protects past sessions against future compromises of private key
    - Reorder system and services cipher suites to ensure the ECDHE suites are prioritized, followed by the Diffie-Hellman suites
    - Configure systems and services to enable other non-Diffie-Hellman key exchange cipher suites from the list of cipher suites offered by the SSL client
- In addition to the FIPS-199 provisions cited in "Security and Privacy Requirements for Information Technology Procurements" Per the NIST SP 800-161,"Supply Chain Risk Management Practices for Federal Information Systems and Organizations," the contractor must comply with the NIST SP 800-161, and ensure that all FIPS-199 categorized systems incorporate language enforcing the security control family, "Supply Chain Risk Management" (SR), and all of the applicable security control enhancements within that same security control family, SR, as defined in the most current, finalized version of the NIST SP 800-53 per control assignments defined in the most current, finalized version of the NIST SP 800-53B and any subsequent security controls on Supply Chain Risk Management in any future, finalized publications of the NIST
- The contractor must comply with the Foreign Investment Risk Review Modernization Act of 2018 (FIRRMA), and with its amendment, the Federal Acquisition Circular (FAC) 2019-05
- Prior to contract award the CO must ensure appropriate compliance with 889 and 15 CFR Part 7 has been completed through signing of NDAA-889-Representation-Form-with-Clauses.pdf. If this attestation or representation is not a part of this submission, then the award must go to the vendor that adheres to the requirements (in keeping with the NDAA/Section 889, 15 CFR Part 7 guidelines).
- Supplemental information related to NDAA Section 889 Compliance (page 39 of the September 2020 "Security and Privacy Requirements for Information Technology Procurements pdf)
  The current list of prohibited entities includes:

    - Dahua Technology Company
    - Hangzhou Hikvision Digital Technology Company
    - Huawei Technologies Company
    - Hytera Communications Corporation
    - ZTE Corporation
- Effective March 22, 2021, the Department of Commerce released Title 15 of the Code of Federal Regulations (CFR) Part 7, "Securing the Information and Communications Technology and Services (ICTS) Supply Chain" to implement provisions of Executive Order 13873. Specifically, 15 CFR Part 7 prohibits ICTS Transactions from foreign adversaries and establishes a framework for rapidly responding to supply chain risk incidents. Per 15 CFR Part 7, the current prohibited list of foreign adversaries includes:
    - The People's Republic of China including the Hong Kong Special Administrative Region (China).
    - Republic of Cuba (Cuba).
    - Islamic Republic of Iran (Iran).
    - Democratic People's Republic of Korea (North Korea).
    - Russian Federation (Russia); and
    - Venezuelan politician Nicolas Maduro (Maduro Regime)

  ICST Transactions are defined by 15 CFR Part 7 as any acquisition, importation, transfer, installation, dealing in, or use of any information and communications technology or service, including ongoing activities, such as managed services, data transmission, software updates, repairs, or the platforming or data hosting of applications for consumer download

11.3 Internet Protocol version 6 (IPv6)

For IPv6, the contractor shall provide COTS solutions that are IPv6 capable. An IPv6 capable system or product shall be capable of receiving, processing, transmitting and forwarding IPv6 packets and/or interfacing with other systems and protocols in a manner similar to that of IPv4. Specific criteria to be deemed IPv6 capable are:

- An IPv6 capable system that meets the IPv6 base requirements defined by the USGv6 Profile (http://www.antd.nist.gov/usgv6/profile.html).
- Systems being developed, procured or acquired shall maintain interoperability with IPv4 systems/capabilities.
- Systems shall implement IPv4/IPv6 dual-stack and shall also be built to determine which protocol layer to use depending on the destination host it is attempting to communicate with or establish a socket with. If either protocol is possible, systems shall employ IPv6.

The contractor shall provide IPv6 technical support for system development, implementation and management.

Per OMB-M-17-12, Preparing for and Responding to a Breach of Personally Identifiable Information, the following requirements statements should be added to all SOWs/SOOs/PWSs/BPAs/MOUs/IAAs/MOUs/ISAs that include the management of Personally Identifiable Information (PII) and / or Sensitive Personally Identifiable Information (SPII):

- The contractor shall cooperate with and exchange information with agency officials, as determined necessary by the agency, in order to effectively report and manage a suspected or confirmed breach.

- The contractor and subcontractors (at any tier) shall properly encrypt PII in accordance with OMB Circular A-130 and other applicable policies and to comply with any agency-specific policies for protecting PII;
- The contractor shall complete regular Department training for contractors and subcontractors (at any tier) on how to identify and report a breach;
- The contractor and subcontractors (at any tier) shall report a suspected or confirmed breach in any medium or form, including paper, oral, and electronic, as soon as possible and without unreasonable delay, consistent with the agency's incident management policy and US-CERT notification guidelines;
- The contractor and subcontractors (at any tier) shall maintain capabilities to determine what Federal information was or could have been accessed and by whom, construct a timeline of user activity, determine methods and techniques used to access Federal information, and identify the initial attack vector;
- The contractor shall allow for an inspection, investigation, forensic analysis, and any other action necessary to ensure compliance with this Federal and Department PII Breach Response policies (such as OMB-M-17-12), the Department's breach response plan, and to assist with responding to a breach;
- The contractor shall identify roles and responsibilities, in accordance with Federal and Department PII Breach Response policies (such as OMB-M-17-12), and the agency's breach response plan; and,
- The contractor shall be aware that a report of a breach shall not, by itself, be interpreted as evidence that the contractor or its subcontractor (at any tier) failed to provide adequate safeguards for PII.

11.4 Reporting of Data Security Breaches

Per OMB-M-17-12, Preparing for and Responding to a Breach of Personally Identifiable Information, the following requirements statements should be added to all SOWs/SOOs/PWSs/BPAs/MOUs/IAAs/MOUs/ISAs that include the management of Personally Identifiable Information (PII) and / or Sensitive Personally Identifiable Information (SPII):

- The contractor shall cooperate with and exchange information with agency officials, as determined necessary by the agency, in order to effectively report and manage a suspected or confirmed breach.
- The contractor and subcontractors (at any tier) shall properly encrypt PII in accordance with OMB Circular A-130 and other applicable policies and to comply with any agency-specific policies for protecting PII;
- The contractor shall complete regular Department training for contractors and subcontractors (at any tier) on how to identify and report a breach;
- The contractor and subcontractors (at any tier) shall report a suspected or confirmed breach in any medium or form, including paper, oral, and electronic, as soon as possible and without unreasonable delay, consistent with the agency's incident management policy and US-CERT notification guidelines;
- The contractor and subcontractors (at any tier) shall maintain capabilities to determine what Federal information was or could have been accessed and by whom, construct a timeline of user activity, determine methods and techniques used to access Federal information, and identify the initial attack vector;
- The contractor shall allow for an inspection, investigation, forensic analysis, and any other action necessary to ensure compliance with this Federal and Department PII Breach Response policies (such as OMB-M-17-12), the Department's breach response plan, and to assist with responding to a breach;

- The contractor shall identify roles and responsibilities, in accordance with Federal and Department PII Breach Response policies (such as OMB-M-17-12), and the agency's breach response plan; and,
- The contractor shall be aware that a report of a breach shall not, by itself, be interpreted as evidence that the contractor or its subcontractor (at any tier) failed to provide adequate safeguards for PII.

If there is a suspected or known breach/disclosure of PII due to lost, theft, intercepted transfer, or other, the contractor must ensure that this breach is reported to the agency as soon as the contractor has knowledge of it. Per Office of Management and Budget Memorandum M-17-12, Federal agencies have a requirement to report breaches of PII security to the United States Computer Emergency Response Team (US-CERT)." The (PO) must notify the department within 60 minutes of discovering the incident (and the agency should not distinguish between suspected or confirmed breaches). The data security plan must be written to reflect this requirement, and the contractor must provide sufficient notification and documentation of the suspected loss, as it is understood at the time of notification to the agency for this requirement to be met. Follow-up reports of the final status of loss events will also be prepared by the contractor within a reasonable period of time as advised by the COR.

11.5 NON-PUBLIC-FACING WEBSITES:

- Implement capabilities for all inbound network traffic to pass through a web content filter, which provides anti-phishing, anti-malware, and blocking of malicious websites (e.g., fake software updates, fake antivirus offers, and phishing offers)
- In accord with OMB Memorandums M-17-06, and M-15-13, and M-08-23, M-10-23, and with Binding Operational Directive (BOD) BOD-18-01, and with the NIST SP 800-52 and with the NIST SP 800-44, all Federal websites and web services must be accessible through a secure connection (HTTPS only, with HSTS), and e-mail applications must have SMTP enabled. The use of HTTPS is encouraged on intranets, but not explicitly required.
- In accord with BOD-18-01: In accordance with OMB Memorandum M-08-23, in order to ensure Domain Name System Security (DNSSEC), all Federal websites must be hosted on a *.gov location.
- Web Security: In accordance with BOD-18-01, Agencies must ensure all publicly accessible Federal websites and web services provide service through a secure connection (HTTPS-only, with HSTS); SSLv2 and SSLv3 are disabled on web servers, and DES and RC4 ciphers are disabled on web servers; and must provide a list to DHS of agency second-level domains that can be HSTS preloaded, for which HTTPS will be enforced for all subdomains.

11.6 Policies and Requirements for Public Websites

- If an official public-facing website will be developed, modified, or maintained, then, in accord with OMB Memorandum M-17-06, each agency must use only an approved .gov or .mil domain for its official public-facing websites. The requirement to use only approved government domains does not apply in circumstances where the agency is a user or a customer of a third-party website or service that resides on a non-governmental domain.
- For requirements involving web applications, web servers, and web services, the contractor shall follow the policies, principles, standards, and guidelines on information security and privacy, in accordance with FISMA, and implement security and privacy requirements as set

forth in OMB Circular A-130 and National Institute of Standards and Technology (NIST) Special Publication 800-44, Guidelines on Securing Public Web Servers.

- The public expects Federal Government websites to be secure and their interactions with those websites to be private. The contractor shall comply with requirements specified in OMB Memorandum M-15-13, Policy to Require Secure Connections across Federal Websites and Web Services, that requires that all publicly accessible Federal websites and web services only provide service through a secure connection (HTTPS with HSTS).
- The contractor shall use only an approved .gov or .mil domain for official public-facing websites. The requirement to use only approved government domains does not apply in circumstances where the Department is a user or a customer of a third-party website or service that resides on a non-governmental domain. Department use of third-party websites and applications must comply with all relevant privacy protection requirements and a careful analysis of privacy implications as specified in OMB Memorandum M-10-23, Guidance for Agency Use of Third-Party Websites.
- The contractor shall ensure compliance with Federal requirements to maintain public/external facing servers and services to use native IPv6. All procurements of networked information technology shall comply with Federal Acquisition Regulation (FAR) requirements for use of the U.S. Government IPv6 Profile and Test Program for the completeness and quality of their IPv6 capabilities
- Transport Layer Security (TLS 1.2)
  The contractor shall develop all websites and web services in accordance with Department of Education standards and the Department of Homeland Security's Binding Operational Directive (DHS BOD 18-01). Department of Education standards require systems, application appliances, or websites to:
  • Utilize Transport Layer Security (TLS 1.2)
  • SSL certificates, certificates must be issued to support TLS 1.2 and must use SHA-256 (SHA-2) equivalent hash functions.

- DHS BOD 18-01 requires any system, application appliance, or website to:
  • Implement the requirements described above on all internal and external facing websites
  • Employ a current and secure TLS version for all websites
  • Use Secure Hash Algorithm 2 (SHA-256 (SHA-2)) at a minimum for all TLS functions.

11.7 FOR CLOUD SOLUTIONS:

- Implement controls to ensure that all publicly accessible externally hosted Department websites and web services only provide service through a secure connection, (such as the Hypertext Transfer Protocol Secure (HTTPS)).
- Only utilize FedRAMP approved cloud solutions. FedRAMP is mandatory for Federal agency cloud deployments and service models at the low and moderate risk impact levels.
- If a cloud solution will be used, in accordance with the FISMA, and with the NIST SP 800-145, "The NIST Definition of Cloud Computing," An ED-issued, FedRAMP-Compliant Authorization To Operate (ATO) is a Federal and a Departmental requirement, and one must be obtained. To achieve proper Information Security Continuous Monitoring (ISCM) of any system(s) in the cloud, via the Cloud Service Provider (CSP),then some Service Level Agreements (SLA[s]) must be included, as a part of the contract, and appropriate level(s) and type(s) of monitoring must be specified in the respective (SLA)s., and the SLA(s) must be kept with the contract, and available with the contract, at all times."

11.8 FOR CYBEROPERATIONS, PENETRATION TESTING, VULNERABILITY SCANNING, INTRUSION DETECTION, AND INCIDENT RESPONSE FUNCTIONS:

- Implement scanning capabilities that assess for vulnerabilities using only Security Content Automation Protocol (SCAP) validated products
- Perform penetration and regular vulnerability testing and scanning of systems, IT devices, and websites. Vulnerability scanning shall be conducted at least monthly, with reports provided to the Department.
- Maintain the tools and capabilities to support asset discovery, to include passive network monitoring, active network monitoring, and automated network mapping
- Maintain tools and capabilities to support behavior monitoring, to include NetFlow analysis and network traffic capture, which captures the Transmission Control Protocol/Internet Protocol (TCP/IP) stream, allowing for replay of activity to determine what happened during a breach or incident
- Maintain tools and capabilities for intrusion prevention, to include host intrusion prevention systems (HIPS) and network intrusion prevention systems (NIPS)
- Maintain a firewall system designed to prevent unauthorized access to or from any contractor systems and network
- Maintain tool and capabilities to perform Security Incident/Event Management and Analysis, to include centralized logging, log correlation, and a Security Information and Event Management (SIEM) solution that provides centralized monitoring of security incidents; network behavior analytics to provide behavior-based detection to help protect against zero-day attacks; and a quarantine/sandbox environment that will isolate and analyze live traffic and/or suspected malware
- Maintain tools and capabilities to perform vulnerability and risk management and analysis to include threat intelligence threat hunt capabilities, sharing platforms, risk management or trouble ticketing system, anti-malware and anti-phishing services
- Maintain tools and capabilities to provide security situational awareness and visibility throughout the enterprise; this includes capabilities for full packet capture that collects detailed network information at the gateway and makes capture data available to analysts; endpoint incident response that enables searches all endpoints for Indicators of Compromise (IOCs) in a rapid fashion; and encrypted traffic inspection
- If working as a SOC contractor or subcontractor, will provide a Daily Morning Report, 7 days per week, that summarizes the noteworthy daily security activities. Examples include activities such as the daily count of security incidents detected (viruses, malware, etc.), email traffic analysis for spam and phishing attempts, vulnerability scan results and progress in closing open weaknesses from scan results. The contractor is encouraged to propose a world class daily security morning report format, with the most noteworthy performance measures, to include any graphic displays, and charts to enhance reporting
- Provide and maintain automated means of discovering, monitoring, and protecting sensitive data to ensure protection of data in motion, at rest, and in use
- Provide and maintain an automated means of preventing unauthorized users and computing devices from accessing contractor hosted environments, including access via remote access, wired and wireless technologies
- Provide and maintain externally facing web application firewall capabilities providing inbound and outbound traffic filtering
- Provide and maintain an Out of Band network device management solution
- Administer, operate, maintain, configure and tune cybersecurity software and hardware

- Provide full government visibility of continuous monitoring tool configurations and output on a real-time basis as well as historical data/logs
- Maintain the capability to perform periodic penetration testing, and also support for external agency red team testing, penetration testing, cyber hygiene web site vulnerability scanning tests and vulnerability assessments that the Department may need to conduct

11.9 OR GOVERNMENT FURNISHED EQUIPMENT (GFE):

- Implement capabilities to ensure that GFE endpoints are covered by an intrusion prevention system, and by an antivirus (AV) solution using file reputation services, checking files against cloud-hosted, continuously updated malware information
- Implement capabilities to ensure that GFE endpoints are covered by an anti-exploitation tool (e.g., Microsoft's Enhanced Mitigation Experience Toolkit (EMET) or similar)
- Implement capabilities to ensure that GFE endpoints are protected by a browser-based (e.g., Microsoft SmartScreen Filter, Microsoft Phishing Filter, etc.) or enterprise-based tool to block known phishing websites and IP addresses
-

11.10 Other

- When applicable, for the Department as a whole, the contractor shall comply with the most current, finalized version of the Department's Information Security Continuous Monitoring (ISCM) Roadmap."
- In accordance with the NIST SP 800-60, and with the Cyber-Security Risk Management Framework (CRMF), and with the U.S. Department of Education's (ED's) OCIO: 03-112, 'Cyber-Security Policy,' when applicable, the contractor shall support the Information System Owner (ISO) and the Information System Security Officer (ISSO), in categorizing information systems, selecting security controls, inheriting security controls, offering security controls for inheritance, and implementing security controls through the authoring / editing, and validation of security control implementation statements, as well as in the creation and editing of all security documentation and artifacts needed for system security assessment, and for security authorization.

11.11 RECORDS AND CONTROLLED UNCLASSIFIED INFORMATION (CUI):

- "Federal record" as defined in 44 U.S.C. § 3301, includes all information, made or received by a Federal agency in connection with the transaction of public business. ED owns rights to all records produced as part of this contract. Any Contractor rights must be identified as required by FAR 52.227-11 through FAR 52.227-20.
- Federal records must be managed according to the applicable records management laws and regulations, to include the Federal Records Act (44 U.S.C. chs. 21, 29, 31, 33), 36 CFR Chapter XII Subchapter B, and the Privacy Act of 1974 (5 U.S.C. 552a).
- Federal records which are CUI must additionally be managed in accordance with any applicable laws, regulations and government-wide policies (LRGWP) to include EO 13556, 32 CFR Part 2002, ED Directive OCIO 3-113, and NIST-800-171 Revision 2 (or current version).
- Applicability: This clause applies to all Contractors and sub-contractors (hereafter referred to as "Contractors") and must be incorporated into all subcontracts.
- Training Requirements: All Contractors are required to take the annual Information Management Requirements training. If the contract includes CUI the CUI Identification and

Marking Training is required. Additional Category or POC specific trainings may be assigned. Contractor will maintain completion certificates and provide upon request.

- Electronic Information System Requirements: Any electronic information system should address at minimum the following regulations in 36 CFR 1236.10. Agencies must incorporate controls into the system or integrate them into a recordkeeping system that is external to the information system itself (see 36 CFR 1236.20 for recordkeeping system functionalities). Information systems that process, store, or transmit CUI must fulfill the requirements outlined in 32 CFR 2002.14(g).
- Marking Requirements: The Contractor will mark CUI as outlined in Department training.
- Handling and Safeguarding Requirements: The Contractor will ensure that CUI is managed appropriately. The requirements include safeguarding, controlled environments, shipping and mailing or transporting protections, and reproduction protections (see 32 CFR 2002.14(a-e)).
- Contract Completion Requirements: Removal or destruction of records must be in accordance with assigned ED records schedule and must include written concurrence from the CO/COR. If records are removed or destroyed the Contractor must report the incident to ED immediately. Destruction or removal of records without the above requirements is subject to fines and penalties imposed by 18 U.S.C. 2701.
- Compliance with Information Protection Requirements: ED reserves the right to verify compliance with information security requirements established by this contract. The Contractor will fully comply with all ED-initiated inspections as permissible by law.
- Information Security Incidents (ISI) Requirements: Contractors must immediately report any and all suspected security incidents, breaches, and events involving ED information to ED's Computer Incident Response Center (EDCIRC) email: edcirc@ed.gov, and ED's Security Operations Center (EDSOC) email: edsoc@ed.gov; voice: 202-243-6550, regardless of whether the ISI is suspected, known, or determined to involve IT systems operated in support of this contract. In the event of an ISI, ED must be provided immediate access to all IT systems used in support of this contract for inspection and analysis.

11.12 IT ACCESSIBILITY REQUIREMENTS (SECTION 508 OF THE REHABILITATION ACT)

- Section 508 of the Rehabilitation Act, as amended by P.L. 105-220, requires that when Federal agencies develop, procure, maintain, or use information and communication technology (ICT), it shall be accessible to people with disabilities. Products, platforms and services delivered as part of this work statement that are or contain ICT, must conform to the Revised 508 Standards, at 36 C.F.R. § 1194.1 & Apps. A, C & D.
- Applicable Functional Performance Criteria: When using an alternative design or technology that achieves substantially equivalent or greater accessibility and usability by individuals with disabilities than would be provided by conformance to one or more of the requirements in Chapters 4-6 of the Revised 508 Standards, or when Chapters 4-6 do not address one or more functions of ICT. – All requirements apply
- Applicable requirements for software features and components: All WCAG Level AA Success Criteria, 502 Interoperability with Assistive Technology, 503 Application – Applies if client server software (installed on a computer) is a part of the procurement.
- Applicable requirements to Webpage and Web Applications: All WCAG Level AA Success Criteria – Applies if websites or a web-based application (browser based) is part of the procurement.
- Applicable requirements for hardware features and components: Applies if hardware is part of the procurement. (e.g. copiers, fax machines, phones, scanner etc.)
- Applicable support services and documentation: All requirements apply.

- Instructions to Offerors: Provide an Accessibility Conformance Report (ACR) for each commercially available ICT item offered through this contract. Create the ACR using the Voluntary Product Accessibility Template. Complete each ACR in accordance with the instructions provided in the VPAT template. Each ACR must address the applicable Section 508 requirements referenced in the Work Statement. Each ACR shall state exactly how the ICT meets the applicable standards in the remarks/explanation's column, or through additional narrative.
- Acceptance Criteria: Prior to acceptance, the government reserves the right to perform testing on required ICT items to validate the offeror's Section 508 conformance claims. If the government determines that Section 508 conformance claims provided by the offeror represent a higher level of conformance than what is actually provided to the agency, the government shall, at its option, require the offeror to remediate the item to align with the offeror's original Section 508 conformance claims prior to acceptance.